

TECNICATURA UNIVERSITARIA EN CIBERSEGURIDAD

SEGURIDAD EN EL CLOUD SERVICE



Dante Gabriel Balbuena Atar
Profesor: Velando Walter
Tucumán, Tafí Viejo – 26/10/2025

Contenido

1. INTRODUCCIÓN	4
2. DESARROLLO	4
1. Arquitectura de Referencia en la Nube.....	4
1.1 Estructura General	4
1.2 Servicios de Soporte y Seguridad	5
1.3 Alta Disponibilidad y Escalabilidad	5
2. Seguridad de Red: VPC, Firewalls e IAM	6
2.1 Virtual Private Cloud (VPC) y Segmentación	6
2.2 Firewalls y Control de Tráfico	7
2.3 Gestión de Identidades y Accesos (IAM)	7
3.1 Escalabilidad Automática	8
3.2 Balanceo de Carga y Distribución del Tráfico	8
3.3 Alta Disponibilidad Multi-AZ	8
3.4 Estrategia de Redundancia y Recuperación	8
4.1 AWS Key Management Service (KMS)	9
4.2 Cifrado en Tránsito y en Reposo	9
4.3 Control de Acceso Basado en Roles (RBAC)	9
4.4 Cumplimiento y Auditoría	10
5.1 Estrategia de Respaldo Automático	10
5.2 Snapshots y Versionado de Datos	11
5.3 Recuperación ante Desastres (Disaster Recovery – DR)	11
5.4 Cumplimiento y Gobernanza	11
6.1 Supervisión Operativa y Métricas	12
6.2 Auditoría y Trazabilidad	12
6.3 Detección de Amenazas e Inteligencia de Seguridad	13
6.4 Respuesta ante Incidentes	13
6.5 Cumplimiento y Mejora Continua	13
7.1 Desafío 1: Gestión de identidades y accesos en entornos multiusuario	14
7.2 Desafío 2: Cumplimiento normativo continuo (GDPR, ISO/IEC 27017 y 27018)	14
7.3 Desafío 3: Protección frente a ataques DDoS y amenazas avanzadas	14
7.4 Desafío 4: Recuperación ante desastres y resiliencia operativa	15

7.5 Desafío 5: Monitoreo y respuesta ante incidentes.....	15
3. CONCLUSIONES.....	16



1. Introducción

La migración de infraestructuras tecnológicas hacia entornos de nube representa un cambio fundamental en la forma en que las organizaciones gestionan sus datos, aplicaciones y procesos de negocio. Este avance trae consigo ventajas significativas en términos de escalabilidad, disponibilidad y optimización de recursos, pero también plantea nuevos desafíos relacionados con la **seguridad de la información, la privacidad de los datos personales y el cumplimiento normativo**.

El presente trabajo tiene como objetivo **analizar, diseñar y justificar un plan integral de cumplimiento y seguridad** para la empresa ficticia *UGR Tech Secure*, que busca migrar sus operaciones a la nube utilizando **Amazon Web Services (AWS)** como proveedor principal. El enfoque está basado en los estándares internacionales **ISO/IEC 27017** (controles de seguridad para servicios en la nube) e **ISO/IEC 27018** (protección de información personal en nubes públicas), junto con el cumplimiento de las normativas de protección de datos **GDPR** (Unión Europea) y **CCPA/CPRA** (California, EE. UU.).

A lo largo del informe se desarrollan los principales aspectos técnicos y normativos de la migración, incluyendo el **análisis de requisitos de seguridad y cumplimiento**, el **diseño de un plan de implementación de controles**, la **definición de responsabilidades contractuales** mediante SLA y DPA, la **evaluación de riesgos**, y la propuesta de un **plan de auditoría y mejora continua**. Finalmente, se identifican los **principales desafíos** asociados a la adopción del modelo cloud y las **soluciones prácticas** que garantizan la resiliencia, la confidencialidad y la integridad de la información.

2. Desarrollo

1. Arquitectura de Referencia en la Nube

El diseño propuesto para *UGR Tech Secure* se basa en una **arquitectura segura, modular y escalable** implementada sobre **Amazon Web Services (AWS)**. El objetivo es garantizar la protección de los datos financieros y personales (PII), la disponibilidad continua de los servicios y el cumplimiento con las normativas internacionales de seguridad y privacidad.

1.1 Estructura General

La infraestructura se organiza en tres capas principales:

- **Capa de Presentación (Frontend):** Implementada mediante **Amazon CloudFront** (CDN) y un **Application Load Balancer (ALB)** para distribuir el tráfico web hacia instancias de aplicación. El contenido estático (HTML, CSS, imágenes, scripts) se aloja en **Amazon S3** con acceso restringido mediante políticas de bucket y cifrado **AES-256**.
- **Capa de Aplicación (Backend):**

Conformada por **instancias EC2** dentro de una **VPC (Virtual Private Cloud)** segura, dividida en **subredes públicas y privadas**. Las instancias del backend ejecutan los servicios de negocio y están protegidas por **grupos de seguridad (Security Groups)** y **Network ACLs**. El tráfico entre capas está controlado por un firewall interno y monitoreado mediante **AWS Network Firewall**.

- **Capa de Datos:** Se implementa una base de datos administrada **Amazon RDS (PostgreSQL)** alojada en subredes privadas, con cifrado en reposo mediante **AWS KMS (Key Management Service)** y backups automáticos diarios gestionados por **AWS Backup**. Los accesos se realizan únicamente desde las instancias del backend.

1.2 Servicios de Soporte y Seguridad

- **AWS IAM (Identity and Access Management):** gestiona usuarios, roles y políticas basadas en el principio de **menor privilegio**.
- **AWS CloudTrail y AWS Config:** registran y auditan todas las acciones en la cuenta para garantizar trazabilidad y cumplimiento.
- **AWS WAF (Web Application Firewall):** protege la aplicación contra ataques web comunes (SQLi, XSS, DDoS).
- **Amazon GuardDuty:** monitorea patrones de comportamiento sospechosos y posibles amenazas.
- **Amazon CloudWatch:** supervisa métricas de rendimiento y genera alertas automáticas.

1.3 Alta Disponibilidad y Escalabilidad

La arquitectura incluye **Auto Scaling Groups (ASG)** para aumentar o reducir instancias EC2 según la demanda y un **Elastic Load Balancer (ELB)** para distribuir el tráfico entre zonas de disponibilidad.

Se configura un esquema de **Multi-AZ** para la base de datos, garantizando tolerancia a fallos y disponibilidad continua incluso ante interrupciones regionales.

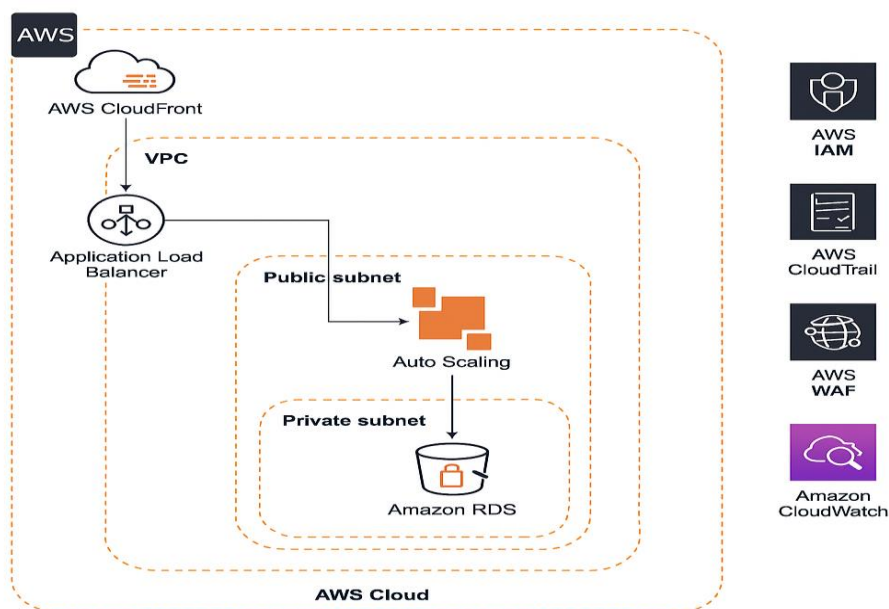


Tabla 1. Servicios de AWS utilizados por capa en la arquitectura de UGR Tech Secure

Capa / Componente	Servicios AWS Utilizados	Función Principal
Capa de Presentación (Frontend)	Amazon CloudFront, Application Load Balancer (ALB), Amazon S3	Distribución de contenido (CDN), balanceo de tráfico HTTP/HTTPS y alojamiento de contenido estático con cifrado.
Capa de Aplicación (Backend)	Amazon EC2, Auto Scaling, AWS Elastic Load Balancer, AWS Lambda	Ejecución de lógica de negocio, escalabilidad dinámica y procesamiento eficiente de solicitudes.
Capa de Datos	Amazon RDS (PostgreSQL), Amazon S3, AWS KMS, AWS Backup	Almacenamiento seguro, cifrado de datos, copias de seguridad automáticas y recuperación ante desastres.
Seguridad y Cumplimiento	AWS IAM, AWS WAF, AWS Shield, Amazon GuardDuty, AWS Config, AWS Security Hub	Protección de identidades, defensa ante ataques DDoS, auditorías, cumplimiento y monitoreo de seguridad.
Monitoreo y Gestión	Amazon CloudWatch, AWS CloudTrail, AWS Organizations, AWS Trusted Advisor	Supervisión del rendimiento, registro de eventos, control centralizado y optimización de recursos.
Resiliencia y Disponibilidad	Multi-AZ Deployment, Cross-Region Replication (S3 CRR), AWS CloudFormation	Alta disponibilidad, replicación de datos entre regiones y restauración automática de infraestructura.

2. Seguridad de Red: VPC, Firewalls e IAM

La seguridad de red constituye el pilar fundamental de toda arquitectura en la nube, ya que garantiza la **confidencialidad, integridad y disponibilidad** de los recursos y los datos. En la infraestructura diseñada para *UGR Tech Secure*, los controles de red se implementan bajo un enfoque de **defensa en profundidad**, combinando segmentación lógica, control de tráfico y gestión granular de identidades y accesos.

2.1 Virtual Private Cloud (VPC) y Segmentación

La arquitectura se implementa dentro de una **Amazon Virtual Private Cloud (VPC)**, la cual permite aislar lógicamente los recursos de la empresa dentro del entorno de AWS. La VPC se divide en **subredes públicas y privadas**, distribuidas en **múltiples zonas de disponibilidad (Multi-AZ)** para garantizar la alta disponibilidad.

- Las **subredes públicas** alojan el **Application Load Balancer (ALB)** y los puntos de entrada controlados desde internet.

- Las **subredes privadas** albergan las **instancias EC2** del backend y la **base de datos Amazon RDS**, evitando su exposición directa a la red pública.
- Se aplican **rutas y tablas de enrutamiento** personalizadas para restringir la comunicación entre las subredes únicamente a lo necesario.

Además, la VPC integra un **AWS NAT Gateway** para permitir que las instancias privadas accedan a internet de forma segura (por ejemplo, para actualizaciones de software) sin quedar expuestas.

2.2 Firewalls y Control de Tráfico

Para la protección perimetral, la empresa utiliza una combinación de herramientas nativas de AWS:

- **AWS Security Groups:** funcionan como firewalls virtuales a nivel de instancia, definiendo qué tráfico está permitido entrar o salir. Cada grupo se configura bajo el principio de **denegar todo por defecto**, habilitando solo los puertos y protocolos estrictamente necesarios (HTTP/HTTPS y conexiones internas seguras).
- **Network ACLs (Access Control Lists):** operan a nivel de subred, ofreciendo una capa adicional de control sobre el tráfico entrante y saliente.
- **AWS WAF (Web Application Firewall):** protege las aplicaciones web contra ataques comunes como **inyecciones SQL, XSS y denegación de servicio (DDoS)**.
- **AWS Shield Standard:** se activa automáticamente para brindar protección básica contra ataques DDoS a nivel de red.

Estos mecanismos combinados garantizan una **segmentación efectiva del tráfico**, minimizan la superficie de ataque y aseguran el cumplimiento de las políticas internas de seguridad de red.

2.3 Gestión de Identidades y Accesos (IAM)

La gestión de identidades y accesos se implementa con **AWS Identity and Access Management (IAM)**, que permite controlar de forma granular quién puede acceder a qué recursos y con qué permisos.

Las configuraciones principales incluyen:

- **Roles y políticas basadas en el principio de menor privilegio**, asegurando que cada usuario o servicio tenga solo los permisos estrictamente necesarios.
- **Autenticación multifactor (MFA)** obligatoria para accesos administrativos y cuentas privilegiadas.
- **IAM Roles for Service Accounts (IRSA)** para que las aplicaciones dentro de AWS (por ejemplo, instancias EC2 o contenedores) puedan acceder a otros servicios sin necesidad de credenciales estáticas.
- **Políticas de rotación de claves de acceso** y uso de **AWS Organizations** para la gestión centralizada de cuentas.

De esta manera, *UGR Tech Secure* aplica un esquema de **Zero Trust**, donde ningún acceso se considera seguro por defecto y cada solicitud es autenticada, autorizada y registrada.

3. Escalabilidad, Alta Disponibilidad y Redundancia

La arquitectura diseñada para *UGR Tech Secure* busca garantizar la **continuidad operativa y la disponibilidad ininterrumpida de los servicios**, incluso ante fallos, incrementos de carga o interrupciones regionales. Para ello, se implementan mecanismos nativos de **Amazon Web Services (AWS)** que permiten escalar dinámicamente los recursos, distribuir el tráfico de forma eficiente y replicar componentes críticos.

3.1 Escalabilidad Automática

El sistema incorpora **Auto Scaling Groups (ASG)** para ajustar automáticamente la cantidad de instancias **Amazon EC2** según la demanda de usuarios.

Cuando se detecta un incremento en el tráfico o en el uso de CPU, el grupo crea nuevas instancias; cuando la demanda disminuye, reduce la capacidad para optimizar costos.

Este enfoque elástico permite que la aplicación mantenga un **rendimiento estable y predecible**, sin intervención manual.

3.2 Balanceo de Carga y Distribución del Tráfico

La distribución del tráfico de red se gestiona mediante un **Elastic Load Balancer (ELB)**, que se encarga de dirigir las solicitudes entrantes hacia las instancias EC2 disponibles en diferentes zonas de disponibilidad (AZ).

El ELB permite monitorear la salud de las instancias y redirigir automáticamente el tráfico en caso de fallos, asegurando una **experiencia continua para los usuarios finales**.

Además, el uso conjunto de **CloudFront (CDN)** y **Route 53** mejora la latencia global y distribuye el contenido de forma óptima según la ubicación geográfica de los clientes.

3.3 Alta Disponibilidad Multi-AZ

La base de datos **Amazon RDS (PostgreSQL)** está configurada en modo **Multi-AZ (Multi-Availability Zone)**, lo que significa que los datos se replican automáticamente en una zona secundaria dentro de la misma región.

En caso de fallo o mantenimiento en la zona principal, AWS realiza un **failover automático**, manteniendo la operación del servicio sin pérdida de datos ni interrupción perceptible.

Este diseño se complementa con **backups automáticos diarios y replicación síncrona**, lo que garantiza la integridad de la información y la continuidad del negocio.

3.4 Estrategia de Redundancia y Recuperación

Para prevenir interrupciones por desastres o incidentes graves, se implementa una **estrategia de redundancia regional**, replicando copias de seguridad críticas en otra región de AWS (por ejemplo, Frankfurt).

Además, los servicios esenciales —como CloudTrail, Config y GuardDuty— almacenan registros en ubicaciones redundantes y cifradas, garantizando que la trazabilidad y la seguridad se mantengan incluso ante fallos mayores.

4. Gestión de Claves y Control de Acceso a Datos

La **protección de datos sensibles** —en especial la información financiera y los datos personales identificables (PII)— es un pilar central en la arquitectura de seguridad de *UGR Tech Secure*. Para garantizar la confidencialidad, integridad y disponibilidad de la información, se implementan políticas de **cifrado integral** y una gestión de claves segura mediante servicios nativos de **Amazon Web Services (AWS)**.

4.1 AWS Key Management Service (KMS)

El cifrado de datos en reposo y en tránsito se realiza utilizando **AWS Key Management Service (KMS)**, que permite crear, rotar y administrar claves criptográficas de manera centralizada.

- Los datos almacenados en **Amazon S3**, **Amazon RDS** y **EBS (Elastic Block Store)** se cifran con claves gestionadas por KMS (AES-256).
- Se aplica el principio de **segregación de funciones**, de forma que los administradores del sistema no tienen acceso a las claves de cifrado ni a los datos cifrados.
- Las políticas de KMS se integran con **AWS IAM**, lo que permite definir permisos específicos sobre quién puede utilizar, administrar o rotar las claves.

Además, las claves maestras (CMK) se auditan a través de **AWS CloudTrail**, que registra cada uso o intento de acceso a una clave, garantizando trazabilidad completa y cumplimiento con las normativas como **ISO/IEC 27018** y **GDPR**.

4.2 Cifrado en Tránsito y en Reposo

Todos los datos que circulan entre los distintos servicios se transmiten bajo **TLS 1.2 o superior**, asegurando la confidencialidad en tránsito.

- Los servidores de aplicación en EC2 utilizan certificados **SSL/TLS** emitidos por **AWS Certificate Manager (ACM)**.
- El tráfico interno entre componentes (por ejemplo, entre EC2 y RDS) también está cifrado para prevenir ataques de interceptación o manipulación.

El cifrado en reposo se aplica a:

- Objetos en **S3** con **Server-Side Encryption (SSE-S3 o SSE-KMS)**.
- Bases de datos **RDS** y **Snapshots**.
- Volúmenes **EBS** y sus respaldos.

Este enfoque garantiza que incluso en caso de acceso físico o lógico no autorizado, los datos permanezcan ilegibles.

4.3 Control de Acceso Basado en Roles (RBAC)

El acceso a los datos se gestiona bajo un esquema de **control de acceso basado en roles (RBAC)**, implementado mediante **AWS IAM**:

- Cada usuario, servicio o aplicación tiene un **rol específico** con permisos mínimos necesarios (principio de menor privilegio).

- Los accesos administrativos requieren **autenticación multifactor (MFA)**.
- Los datos PII están accesibles solo para los procesos o identidades autorizadas, y las políticas de IAM se revisan periódicamente mediante **AWS Config** y **Security Hub**.

Este modelo de permisos segmentado refuerza el paradigma **Zero Trust**, garantizando que ningún acceso sea considerado seguro por defecto y que cada interacción esté autenticada, autorizada y registrada.

4.4 Cumplimiento y Auditoría

La gestión de claves y el control de accesos son auditados de forma continua con **CloudTrail**, que registra todos los eventos relacionados con el uso de claves y accesos a datos sensibles.

Los informes generados se integran en **AWS Security Hub**, permitiendo la correlación de eventos, la detección temprana de incidentes y la verificación del cumplimiento con estándares como **ISO/IEC 27017**, **ISO/IEC 27018**, **GDPR** y **LGPD**.

5. Respaldo y Recuperación de Datos en la Nube

La continuidad operativa y la integridad de la información son pilares fundamentales en la estrategia de seguridad de *UGR Tech Secure*. Por ello, se implementan políticas de **respaldo automático, replicación geográfica y recuperación ante desastres** utilizando herramientas nativas de **Amazon Web Services (AWS)**.

El objetivo es minimizar la pérdida de datos (RPO — *Recovery Point Objective*) y el tiempo de inactividad (RTO — *Recovery Time Objective*) en caso de fallos técnicos, ciberataques o eventos naturales.

5.1 Estrategia de Respaldo Automático

Los respaldos se gestionan mediante **AWS Backup**, un servicio que automatiza la creación, retención y restauración de copias de seguridad.

- Las políticas de backup cubren recursos críticos como **Amazon RDS**, **EBS**, **S3** y **DynamoDB**, garantizando que todos los datos relevantes se almacenen en múltiples zonas de disponibilidad (Multi-AZ).
- Los respaldos se realizan de manera **diaria y cifrada con AWS KMS**, asegurando la confidencialidad de los datos incluso durante los procesos de almacenamiento y restauración.
- Se definen períodos de retención diferenciados: 30 días para datos operativos y 90 días para respaldos de cumplimiento normativo o auditorías.

Además, los **backups se verifican automáticamente** mediante pruebas de restauración programadas, asegurando la integridad de los datos y la funcionalidad de los procedimientos de recuperación.

5.2 Snapshots y Versionado de Datos

Para reforzar la protección, se emplean **Amazon RDS Automated Snapshots** y **EBS Snapshots**, que permiten realizar copias puntuales de bases de datos y volúmenes de almacenamiento.

Estos snapshots pueden replicarse en otras regiones de AWS, proporcionando **redundancia geográfica** ante eventos de pérdida regional o indisponibilidad.

En el caso de los objetos almacenados en **Amazon S3**, se habilita el **versionado (S3 Versioning)**, lo que permite conservar versiones anteriores de los archivos y restaurarlas en caso de eliminación accidental o corrupción.

El uso combinado de **S3 Object Lock** con políticas de retención garantiza que ciertos registros —por ejemplo, logs de seguridad— permanezcan inalterables, en cumplimiento con regulaciones como **GDPR** y **ISO/IEC 27018**.

5.3 Recuperación ante Desastres (Disaster Recovery – DR)

La empresa adopta una estrategia de **recuperación ante desastres híbrida**, combinando respaldos en múltiples zonas de disponibilidad y replicación hacia una región secundaria de AWS (por ejemplo, Frankfurt → París).

El plan de recuperación incluye:

- **Failover automático** para bases de datos RDS Multi-AZ.
- **Infraestructura como código (IaC)** mediante **AWS CloudFormation** para reconstruir entornos críticos rápidamente.
- **Replicación cruzada (Cross-Region Replication – CRR)** para S3, garantizando que los datos críticos estén disponibles incluso ante una falla total de región.
- **Pruebas semestrales de DR**, donde se simula la pérdida de una región para evaluar los tiempos reales de recuperación.

Esta estrategia garantiza que la organización pueda reanudar operaciones en minutos, cumpliendo con los objetivos de continuidad definidos y manteniendo la confianza de los clientes y socios comerciales.

5.4 Cumplimiento y Gobernanza

Todos los procedimientos de respaldo y recuperación están documentados y se auditan a través de **AWS Config** y **CloudTrail**, lo que permite verificar el cumplimiento continuo con las normas **ISO/IEC 27017** (controles de seguridad en servicios en la nube) e **ISO/IEC 27018** (protección de información personal).

Además, las copias de seguridad y los procesos de restauración forman parte del **Plan de Continuidad del Negocio (BCP)** de la organización, alineado con las mejores prácticas del **AWS Well-Architected Framework**.

6. Monitoreo y Detección de Eventos de Seguridad

El monitoreo continuo es un componente esencial dentro de la estrategia de ciberseguridad de *UGR Tech Secure*.

El objetivo es **garantizar la detección temprana de amenazas, comportamientos anómalos y vulnerabilidades** en toda la infraestructura alojada en Amazon Web Services (AWS).

Para ello, se implementa un sistema de **observabilidad integral**, que combina monitoreo de rendimiento, auditoría de configuraciones y detección inteligente de intrusiones mediante servicios nativos de AWS.

6.1 Supervisión Operativa y Métricas

La infraestructura cuenta con un sistema de monitoreo activo basado en **Amazon CloudWatch**, el cual recopila métricas de rendimiento, logs del sistema y eventos personalizados.

- Se configuran **alarmas automáticas** que notifican al equipo de seguridad ante comportamientos fuera de los umbrales definidos, como sobrecarga de CPU, conexiones fallidas o aumentos anómalos en el tráfico de red.
- Los **dashboards de CloudWatch** permiten visualizar en tiempo real el estado de los recursos críticos (EC2, RDS, S3, ELB, VPC).
- Además, se integran métricas de aplicación mediante **CloudWatch Logs Insights**, lo que facilita el análisis detallado de errores o patrones de comportamiento sospechosos.

Este monitoreo constante permite una respuesta proactiva ante incidentes y garantiza la disponibilidad de los servicios.

6.2 Auditoría y Trazabilidad

Para garantizar la integridad de las operaciones y el cumplimiento normativo, la empresa utiliza **AWS CloudTrail**, que registra de forma continua todas las llamadas a la API, cambios en la configuración y accesos a los recursos.

Cada evento queda documentado con fecha, hora, identidad del usuario, dirección IP y servicio afectado.

Estos registros:

- Se almacenan cifrados en **Amazon S3** con políticas de retención de 365 días.
- Son analizados periódicamente por **AWS Config**, que evalúa desviaciones respecto a las configuraciones seguras establecidas por la organización.
- Forman parte de las auditorías internas y externas exigidas por los estándares **ISO/IEC 27017** y **ISO/IEC 27018**.

Esta trazabilidad completa permite detectar rápidamente acciones no autorizadas y mantener evidencia verificable para fines forenses o regulatorios.

6.3 Detección de Amenazas e Inteligencia de Seguridad

La capa de seguridad avanzada se implementa con **Amazon GuardDuty**, un servicio de detección de amenazas que analiza los logs de CloudTrail, VPC Flow Logs y DNS Logs para identificar patrones anómalos y posibles actividades maliciosas.

GuardDuty permite detectar:

- Escaneos de puertos.
- Conexiones a dominios sospechosos.
- Uso no autorizado de credenciales.
- Comportamientos fuera del patrón normal de los usuarios o servicios.

Cuando se identifica una amenaza, se genera una alerta automática que se integra con **AWS Security Hub**, donde se centraliza la información de seguridad de toda la cuenta y se correlacionan los eventos para una respuesta coordinada.

Además, se puede vincular con herramientas SIEM externas (como **Splunk** o **IBM QRadar**) para análisis más avanzados o cumplimiento de auditorías externas.

6.4 Respuesta ante Incidentes

El proceso de respuesta ante incidentes se estructura bajo un enfoque **automatizado y orquestado**.

Mediante **AWS Lambda**, se ejecutan acciones automáticas cuando se detectan incidentes críticos, como:

- Aislar una instancia EC2 comprometida.
- Revocar credenciales IAM afectadas.
- Generar tickets automáticos en el sistema de gestión de incidentes.

Estas respuestas automáticas reducen el tiempo de contención y minimizan el impacto de ataques o configuraciones indebidas.

Además, las alertas se integran con **Amazon SNS** para notificar al equipo de seguridad por correo o mensajería instantánea en tiempo real.

6.5 Cumplimiento y Mejora Continua

El sistema de monitoreo se alinea con el **AWS Well-Architected Framework (pilar de seguridad)**, y los resultados de CloudTrail, Config y GuardDuty se revisan mensualmente para asegurar la conformidad con los controles de **ISO/IEC 27017** y **27018**.

De esta forma, la empresa mantiene un **ciclo de mejora continua**, donde los eventos detectados alimentan nuevos ajustes en las políticas de acceso, cifrado y respuesta ante incidentes.

7. Desafíos y Soluciones

Durante la implementación de la infraestructura en la nube de *UGR Tech Secure*, pueden surgir diversos desafíos relacionados con la seguridad, el cumplimiento normativo y la gestión operativa. A continuación, se describen los principales retos identificados y las soluciones propuestas para garantizar la continuidad, seguridad y gobernanza del entorno.

7.1 Desafío 1: Gestión de identidades y accesos en entornos multiusuario

Descripción:

El manejo de múltiples cuentas, roles y permisos puede generar riesgos de accesos indebidos o privilegios excesivos, especialmente en entornos donde colaboran distintos equipos y proveedores externos.

Solución:

Implementar una estrategia centralizada de gestión de identidades con **AWS Identity and Access Management (IAM)** y **AWS Organizations**, aplicando el principio de menor privilegio.

Se exige **autenticación multifactor (MFA)** para usuarios administrativos y se automatiza la rotación de credenciales. Además, se aplican revisiones trimestrales de permisos y se utiliza **AWS CloudTrail** para auditar todas las acciones.

7.2 Desafío 2: Cumplimiento normativo continuo (GDPR, ISO/IEC 27017 y 27018)

Descripción:

Mantener la conformidad constante con los estándares y normativas internacionales puede resultar complejo debido a actualizaciones regulatorias y cambios en la infraestructura.

Solución:

Adoptar un enfoque de cumplimiento continuo mediante herramientas nativas como **AWS Config** y **AWS Security Hub**, que evalúan de forma automática las configuraciones contra marcos de referencia (CIS, ISO, NIST).

Se implementa un ciclo de auditorías internas semestrales y revisiones externas anuales para validar la conformidad con las normas de seguridad y protección de datos.

7.3 Desafío 3: Protección frente a ataques DDoS y amenazas avanzadas

Descripción:

Las aplicaciones web expuestas a internet pueden ser blanco de ataques de denegación de servicio (DDoS) o de explotación de vulnerabilidades comunes como inyección SQL o cross-site scripting (XSS).

Solución:

Implementar **AWS Shield Standard** para mitigación automática de ataques DDoS y **AWS WAF (Web Application Firewall)** con reglas personalizadas que bloqueen tráfico malicioso.

Estas soluciones se complementan con **Amazon GuardDuty** para detección temprana de amenazas y **CloudFront** como capa adicional de distribución y filtrado.

7.4 Desafío 4: Recuperación ante desastres y resiliencia operativa

Descripción:

Ante fallos regionales o desastres naturales, la pérdida de disponibilidad de servicios críticos podría impactar gravemente en la continuidad del negocio.

Solución:

Aplicar una arquitectura **Multi-AZ y Multi-Región**, con replicación cruzada entre regiones mediante **S3 Cross-Region Replication (CRR)** y **RDS Multi-AZ**.

Además, los respaldos automáticos gestionados por **AWS Backup** y los planes de recuperación probados con **CloudFormation** aseguran la restauración rápida de servicios.

7.5 Desafío 5: Monitoreo y respuesta ante incidentes

Descripción:

En entornos distribuidos y dinámicos, detectar y responder a incidentes de seguridad de manera oportuna puede ser un desafío constante.

Solución:

Centralizar la observabilidad con **CloudWatch**, **CloudTrail** y **Security Hub**, implementando alertas automáticas mediante **Amazon SNS** y acciones de respuesta inmediata con **AWS Lambda**.

De esta manera, la empresa mantiene un sistema de detección y respuesta automatizado, reduciendo el tiempo de exposición ante incidentes.

Desafíos y Soluciones

Desafío	Solución
 Gestión de identidades en entornos multiusuario	 Uso de IAM Roles y MFA
 Asegurar cumplimiento continuo	 Automatización de auditorías con AWS Config y Security Hub
 Proteccion frente a ataques DDoS	 AWS Shield y WAF

3. Conclusiones

La migración de *UGR Tech Secure* a **Amazon Web Services (AWS)** permitió diseñar una infraestructura segura, resiliente y conforme a las principales normas internacionales. La aplicación de los estándares **ISO/IEC 27017** y **ISO/IEC 27018**, junto con el cumplimiento de las regulaciones **GDPR** y **CCPA/CPRA**, garantizó la protección de los datos personales y la seguridad de los servicios en la nube.

Mediante controles como el cifrado con **AWS KMS**, la gestión de accesos con **IAM**, auditorías con **CloudTrail** y acuerdos formales (SLA y DPA), la empresa logra mantener la confidencialidad, integridad y disponibilidad de la información.

En síntesis, el plan propuesto demuestra que una migración a la nube puede ser **segura, transparente y sostenible**, siempre que se base en un enfoque integral que combine **tecnología, cumplimiento normativo y cultura de seguridad**.

4. Referencias

Amazon Web Services. (s. f.). *Programas de cumplimiento en AWS*. AWS. Recuperado el 26 de octubre de 2025, de <https://aws.amazon.com/es/compliance/programs/>

Amazon Web Services. (s. f.). *Preguntas frecuentes sobre ISO/IEC 27017*. AWS. Recuperado el 26 de octubre de 2025, de <https://aws.amazon.com/es/compliance/iso-27017-faqs/>

Amazon Web Services. (s. f.). *Preguntas frecuentes sobre ISO/IEC 27018*. AWS. Recuperado el 26 de octubre de 2025, de <https://aws.amazon.com/es/compliance/iso-27018-faqs/>

Google Cloud. (s. f.). *Cumplimiento de seguridad en la nube*. Google Cloud. Recuperado el 26 de octubre de 2025, de <https://cloud.google.com/compliance?hl=es>

Microsoft. (s. f.). *Centro de confianza de Microsoft: Cumplimiento*. Microsoft Learn. Recuperado el 26 de octubre de 2025, de <https://learn.microsoft.com/es-es/azure/compliance/>

Microsoft. (s. f.). *ISO/IEC 27017: Controles de seguridad para servicios en la nube*. Microsoft Learn. Recuperado el 26 de octubre de 2025, de <https://learn.microsoft.com/es-es/azure/compliance/offerings/offering-iso-27017>

Microsoft. (s. f.). *ISO/IEC 27018: Protección de datos personales (PII) en nubes públicas*. Microsoft Learn. Recuperado el 26 de octubre de 2025, de <https://learn.microsoft.com/es-es/azure/compliance/offerings/offering-iso-27018>